# USB Monitor — API y modelo de seguridad

Documentación del proyecto · 5 de 5

Versión del sistema: noviembre de 2026

## Autenticación

### Sesión del panel (personas)

Login con usuario y contraseña; la sesión viaja en cookie. Las contraseñas se guardan con hash y la verificación aplica el mismo criterio en el login y en el desbloqueo: 5 intentos fallidos bloquean la cuenta 15 minutos.

### Token del agente (máquinas)

- Cada equipo tiene un token propio, generado por un administrador desde Equipos o provisionado por la instalación remota.
- El panel guarda solo la **huella SHA-256** del token (`agentTokenHash`); el token en sí se muestra una sola vez al generarlo.
- El agente lo presenta en cada llamada: `Authorization: AgentToken <token>`.
- Generar un token nuevo para un equipo **invalida el anterior** en el acto.
- La clave API de usuario **ya no autentica agentes** (dejó de aceptarse en noviembre de 2026): un agente necesita su token de equipo sí o sí.
- En la PC, el token se guarda cifrado en `server.json` (formato `ENC:`). El registro del agente anota solo su huella parcial (12 caracteres) y su longitud.

## Rutas que usa el agente

**Ruta** — Para qué

**`GET /api/agent/ping`** — Comprobar conexión y credenciales.

**`POST /api/usb-event`** — Enviar eventos (conexión, bloqueo, extracción, arranque/parada del servicio).

**`POST /api/usb-event/connected-status`** — Reportar los dispositivos conectados y su tipo.

**`POST /api/usb-event/pending-unlock`** — Registrar un bloqueo en el panel.

**`POST /api/usb-event/pending-close`** — Cerrar un bloqueo (extracción o desbloqueo).

**`GET /api/whitelist/check`** — Consultar si un serial está en la lista blanca.

**`POST /api/usb-auth`** — Verificar la contraseña de desbloqueo.

**`GET /api/agent/config`** — Leer los ajustes que le afectan (empuje y sondeo de respaldo).

**`GET /api/agent/owner`** — Dueño del equipo y modo de desbloqueo vigente, sin credenciales.

**`GET /api/agent/owner-hash`** — Huella cifrada de la contraseña del dueño, para la emergencia sin red.

**`POST /api/agent/offline-attempts`** — Subir los intentos de emergencia cuando vuelve la red.

**`POST /api/agent/provision-token`** — (Solo sesión de administrador) Generar el token de un equipo.

El panel responde a los errores de contraseña con un 401 genérico (sin decir si falló la contraseña, el dueño o el bloqueo) para no dar pistas; los casos «no está en la lista blanca» y «desbloqueo desactivado» devuelven 403 con su mensaje, porque ahí no hay secreto que proteger.

# Las reglas del desbloqueo

1. Sin lista blanca no hay contraseña: un dispositivo desconocido no se puede desbloquear con ninguna credencial, ni la del administrador.
2. Con lista blanca, la contraseña es obligatoria siempre (segundo factor): la del **dueño del equipo** o la de un administrador. En modo «solo administradores», solo administradores.
3. El desbloqueo dura hasta que el dispositivo se extrae. Al reconectarlo, se pide de nuevo.
4. Nadie aprueba nada a mano: no existe flujo de aprobación. El administrador es una credencial más, no un permiso.
5. Los intentos quedan auditados: quién, cuándo, desde qué equipo y con qué resultado.

# Modelo de amenazas, dicho claramente

- Esto es software en espacio de usuario, **no un driver**. Un administrador local decidido puede detener el servicio. La defensa del sistema es otra: **detectarlo y dejar evidencia** (el panel marca los equipos que dejan de dar señales, con la última señal recibida).
- El agente revierte todo lo que toca («sin huella»), así que tampoco sirve para dejar una PC «castigada» después de desinstalarlo.
- La emergencia sin red es un compromiso consciente: permite desbloquear sin servidor con la contraseña del dueño cifrada localmente, limitada a 5 intentos cada 15 minutos y auditada a posteriori. Se puede desactivar en Ajustes.
- El apagado opcional ante dispositivos desconocidos está desactivado por defecto: es una medida dura, con cuenta atrás cancelable, pensada para puestos muy sensibles.
- La instalación remota por WinRM con cuentas locales usa autenticación Basic sobre HTTP: las credenciales viajan en claro dentro de la red local. Para entornos que no lo acepten, la vía es WinRM sobre HTTPS o la instalación local con el ejecutable.
- En producción, el panel debe servirse compilado (`npm run build` y `npm run start`): el servidor de desarrollo es lento y no aplica igual las cabeceras de seguridad.

# Qué no hace el sistema

- No cifra ni inspecciona el contenido de los dispositivos: decide si se pueden usar, no qué llevan.
- No bloquea impresoras ni la red USB que el equipo ya esté usando al arrancar.
- No funciona fuera de Windows en el lado del agente.